Aegis OS: A Transactional Multi-Tenant Operating System Runtime for Eliminating Authorization Fatigue in Autonomous Coding Agents

Hui Zhao
Heurion Research
huizhao@heurion.org

Preprint — October 2026

Abstract

Autonomous coding agents such as Google Antigravity (`agy`), Anthropic Claude Code (`claude`), and OpenAI Codex CLI (`codex`) execute multi-step software engineering workflows on developer workstations and cloud hosts. Existing agent execution environments face a *Security–Autonomy Dilemma*: operators must choose between per-action confirmation prompts, which interrupt workflows on 45%–57% of tool calls in our benchmark trajectories and induce severe authorization fatigue, or unconfined execution (`-yolo` / `-dangerously-skip-permissions`), which exposes host files, SSH/cloud credentials, and API tokens to prompt injection and hallucination risks. Furthermore, concurrent agents editing a shared working tree clobber one another's changes, while passing large artifacts inline through LLM context windows incurs high token overhead.

We present **Aegis OS** (`aegis-os`), a transactional, multi-tenant Agent Operating System Runtime written in Rust and exposed via the Model Context Protocol (MCP). Aegis OS shifts the authorization boundary from individual tool calls to *transactional workspace boundaries*. Each agent operates inside a kernel-enforced OS sandbox (evaluated on macOS Seatbelt `sandbox-exec`, with a Linux Bubblewrap namespace backend and microVM control-plane interface) backed by an APFS Copy-on-Write (CoW) shadow workspace (`libc::clonefile`), an identity-pinned HTTP Egress Proxy with boundary secret injection, and an intra-organization Inter-Agent Communication (IPC) bus paired with Content-Addressable Storage (CAS). Inside its isolated CoW workspace and organization IPC bus, an agent executes with zero confirmation prompts; human approval or TTL-scoped session leases are required only when committing diffs to the host via an LCS-based Diff3 3-Way Merge Engine. Across 1,500 runtime tool calls spanning five trajectory templates and 40 end-to-end adversarial attacks, Aegis OS reduces human confirmation prompts by **94.19%–99.88%**, lowers the attack success rate on evaluated vectors from **100.0% to 0.0%**, clones 1,000-file (78.1 MB) workspaces in **6.28 ms** (**18.0× faster** than full copy), and preserves 100% of disjoint multi-agent edits while catching 10/10 overlapping line conflicts.

1 Introduction

The paradigm of AI-assisted software engineering has shifted from passive single-line code completion to autonomous, long-horizon coding agents—such as Google Antigravity (`agy`), Anthropic Claude Code (`claude`), OpenAI Codex CLI (`codex`), SWE-agent [25], and OpenHands [20]. Unlike conversational assistants, coding agents iteratively explore repositories, modify files across multiple modules, invoke compilers and test suites, query external APIs, and coordinate subtasks with peer agents [12, 3].

Despite advances in model reasoning, the execution substrate for local coding agents remains caught between usability and safety. When agent CLIs mutate the developer's live working tree directly, every file write (`fs_write`, `fs_edit`) and shell command (`proc_exec`) carries immediate side effects on the host. Consequently, agent frameworks rely heavily on *action-level human-in-the-loop (HITL) confirmation prompts*.

1.1 The Security–Autonomy Dilemma

In practice, action-level prompting and existing in-place CLI sandboxes exhibit three systemic limitations:

1. **Severe Authorization Fatigue:** A 30-step bugfix, refactoring, or security-audit trajectory typically invokes 13 to 18 mutating or state-changing operations. Prompting the developer on 45%–57% of tool invocations (as measured in §5) fragments autonomous workflow continuity to streaks of 4–7 steps and habituates users to reflexively

approve prompts without inspecting arguments—a well-documented failure mode in usable security [9, 2].

2. **Risk of Unconfined "YOLO" Mode and In-Place Mutation:** To avoid constant interruptions, developers frequently enable bypass flags (`-dangerously-skip-permissions`, `-yolo`) or rely on lightweight in-place CLI sandboxes (e.g., Claude Code or Codex native Seatbelt/Landlock modes). In unconfined mode, an indirect prompt injection [10, 8, 26] can overwrite files outside the repository, read host credentials (`~/.ssh/id_rsa`, `~/.aws/credentials`, `~/.kube/config`), or exfiltrate raw API keys (`$GITHUB_TOKEN`) from process environment variables. Even when native CLI sandboxes restrict writes to the project directory, agents still mutate the live host working tree in place without transactional rollback or boundary secret injection.

3. **Multi-Agent Workspace Collisions and Context Bloat:** Developers increasingly run heterogeneous agents in parallel (e.g., `agy` for architecture, `claude` for backend logic, and `codex` for test generation) [23, 11]. When sharing a live working directory without manual `git worktree` management, concurrent edits overwrite one another's changes, while passing large specifications inline through JSON/-text messages bloats LLM context windows.

1.2 Key Insight: Transaction-Boundary Security

Inspired by operating system transactions [17, 16] and user-space filesystem sandboxes [14, 22], our key insight is that *authorization prompts should not guard speculative intermediate actions inside an isolated state space; they should guard irreversible boundary crossings into the host repository or untrusted external networks.*

In Aegis OS, each agent principal is provisioned with: (1) an isolated Copy-on-Write (CoW) shadow workspace cloned from the host repository via APFS `libc::clonefile`, (2) a kernel-enforced OS sandbox that confines child processes and outbound sockets to that shadow workspace and a local loopback proxy, and (3) a local Zero-Trust Egress Proxy that strips raw credentials from the agent's environment and injects secrets only at the network boundary for allowlisted domains. Because intermediate file edits, builds, test runs, and intra-organization IPC messages cannot mutate the host tree or leak raw credentials, Aegis OS auto-allows 100% of in-sandbox operations with zero prompts, deferring human review (or session lease evaluation) to an atomic two-phase `workspace_commit` operation (Table 1).

1.3 Contributions

We design, implement, and evaluate **Aegis OS** (`aegis-os`), a multi-tenant Agent Operating System Runtime in Rust:

- **Transactional CoW VFS with Two-Phase LCS Diff3 Merge (§3.1):** `aos-vfs` uses APFS `libc::clonefile` syscalls to provision isolated shadow workspaces in $O(|F|)$ metadata time (0.71–6.28 ms for 100–1,000 files), supports metadata-time snapshots and rollbacks while preserving compiler build caches (`CARGO_TARGET_DIR`) outside the rollback tree, and implements a two-phase Longest Common Subsequence (LCS) Diff3 3-Way Merge Engine [13] that reconciles concurrent edits from heterogeneous agents while aborting cleanly on overlapping line conflicts.

- **Kernel Sandbox and Identity-Pinned Egress Proxy (§3.2):** `aos-sandbox` and `aos-egress` enforce mandatory access control via macOS Seatbelt (`/usr/bin/sandbox-exec` with file-write, credential-read, AppleEvent, and exact proxy-port network confinement) and a Linux Bubblewrap (`bwrap`) namespace driver, paired with a TCP-pinned HTTP Egress Proxy that injects `$AOS_SECRET_*` tokens at the network boundary.

- **Inter-Agent IPC Bus and Reference-Based CAS (§3.3):** `aos-ipc` provides P2P mailboxes, correlated RPC (`ipc_request`/`ipc_reply`) with broadcast wakeup, topic Pub/Sub, and Content-Addressable Storage (`artifact://<org>/sha256:<hash>`) that reduces in-transit IPC payload tokens by 99.85%.

- **Cedar-Inspired Policy Engine with Commit-Time Poisoning Guards (§3.4):** `aos-policy` implements a five-stage authorization hierarchy inspired by Cedar [6], combining host red-line protection and commit-time sensitive path guards (`.git/hooks`, `.envrc`, `.github/workflows`) with one-shot and TTL-scoped session leases.

- **Empirical Evaluation (§5):** We evaluate Aegis OS on Apple Silicon across 1,500 runtime tool calls, 40 end-to-end process/socket/gateway red-team attacks, multi-scale APFS CoW working-set benchmarks, and multi-agent Rust compilations (`cargo test` and `cargo check`).

Table 1: **Comparison of Agent Execution Substrates** across isolation mechanisms, authorization friction, workspace complexity ($|F|$: file count, $|B|$: byte size, Δ: modified bytes), and multi-agent primitives.

Execution Substrate	Workspace Setup	N-Agent Disk Cost	Prompt Rate (IPR)	OS Kernel MAC	Boundary Secret Inject	Transactional 3-Way Merge	Native IPC + CAS
Host-Interactive (Unconfined CLI)	In-Place (0 ms)	$O(1)$ (Shared Tree)	High (45%–57%)	× (Prompt Only)	× (Raw Env Vars)	× (In-Place Write)	×
Host-YOLO (`-skip-permissions`)	In-Place (0 ms)	$O(1)$ (Shared Tree)	0.0%	× (Unconfined)	× (Raw Env Vars)	× (Silent Clobber)	×
Native CLI Sandbox (`claude`/`codex`)	In-Place (∼6 ms)	$O(1)$ (Shared Tree)	Low–Med	✓ (Seatbelt/Landlock)	× (Env in Sandbox)	× (Shared Working Tree)	×
Container-per-Agent (Docker) [12, 20]	O(Container Init)	$O(N \cdot \text{Layer } \Delta)$	Low	✓ (Linux NS/cgroups)	× (Env in Container)	× (Isolated Volume)	×
AIOS (LLM Scheduler Kernel) [15]	In-Place	$O(1)$ (Shared Tree)	Medium	× (No OS MAC)	× (No Egress Proxy)	× (No CoW Merge)	Partial
Aegis OS (Ours)	**0.71–6.28 ms** ($O(\|F\|)$)	**O(Δ Modified)**	**0.07%–3.33%**	✓ (`sandbox-exec`/`bwrap`)	✓ (`$AOS_SECRET_*`)	✓ (2-Phase LCS Diff3)	✓ (`aos-ipc`)

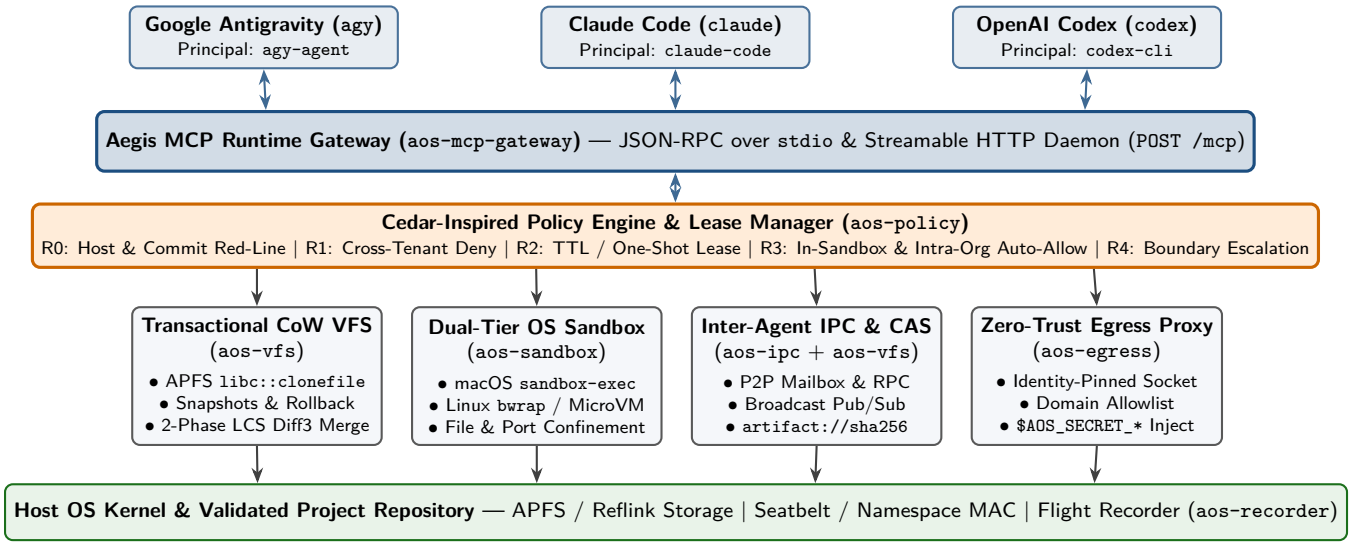


Figure 1: Architecture of the Aegis OS Runtime (`aegis-os`). Coding agents connect via MCP (`stdio` or HTTP daemon) as distinct principals within a tenant organization. The policy engine auto-allows in-sandbox CoW mutations, confined process executions, and intra-organization IPC/CAS operations with zero prompts, while guarding host commits and network egress.

2 Threat Model and Problem Formulation

2.1 System and Adversary Model

We consider a multi-agent deployment where autonomous coding agents $\mathcal{A} = \{a_1, a_2, \ldots, a_m\}$ operate within one or more tenant organizations $\mathcal{O} = \{o_1, o_2, \ldots, o_k\}$. Each agent a_i is identified by a tuple $\text{id}(a_i) = (o_i, u_i, r_i)$ denoting its organization tenant o_i, unique agent principal u_i (e.g., `agy-agent`, `claude-code`, `codex-cli`), and role r_i.

Trusted Computing Base and Enforcement Assumption. We trust the host operating system kernel (macOS XNU/Seatbelt or Linux kernel namespaces) and the Aegis OS Runtime binary (`aegis-os`), which executes outside the agent sandbox. Because MCP is an additive tool protocol, our security guarantees assume that the host agent client is configured to route filesystem mutations and shell execution through `aegis-os` (i.e., built-in unconfined host tools such as raw `Bash` or host `Write` are either disabled in client permissions or intercepted by client `PreToolUse` hooks, as detailed in §4).

Adversarial Threat Vectors (T1–T5). We assume the LLM driving any agent $a_i \in \mathcal{A}$ is untrusted and may issue malicious or erroneous tool calls due to:

- **T1 (Indirect Prompt Injection):** Malicious instructions embedded in repository files, commit logs, issue trackers, or web pages read by the agent [10, 8].
- **T2 (Host Path Escape and Tampering):** Attempting to write files outside the workspace (e.g., `../../etc/hosts`, `~/.zshrc`, or sibling repositories) or staging commit-time hooks (`.git/hooks/pre-commit`, `.envrc`).
- **T3 (Credential Harvesting):** Attempting to read sensitive host credentials (`~/.ssh/id_rsa`, `~/.aws/credentials`, `~/.gnupg`, `~/.kube/config`, `~/.npmrc`, or macOS Keychains).
- **T4 (Network Secret Exfiltration):** Attempting to transmit API tokens or source code to unauthorized external domains (`evil-exfil.org`, `webhook.site`) via HTTP requests or direct socket bypass (`curl -noproxy '*'`).
- **T5 (Cross-Tenant Privilege Escalation):** At-

tempting to read CAS artifacts or inject IPC messages into a different tenant organization $o_j \neq o_i$.

Non-Adversarial Concurrency and Reliability Hazards (H1–H2). Even in benign settings, multi-agent workflows face: **(H1) Concurrent Lost Updates**, where parallel agents overwrite one another's edits on shared files; and **(H2) Multi-File Hallucinated Corruption**, where an agent breaks syntax across dozens of modules during speculative refactoring.

2.2 Evaluation Metrics

Let an agent trajectory $\tau = (s_1, s_2, \ldots, s_T)$ be a sequence of T runtime tool calls. Let $\text{Prompt}(s_t) \in \{0, 1\}$ indicate whether call s_t halts execution to request interactive human approval. We define the **Interruption Prompt Rate (IPR)** across a workload $\mathcal{T}$ as:

$$\text{IPR}(\mathcal{T}) = \frac{\sum_{\tau \in \mathcal{T}} \sum_{s_t \in \tau} \text{Prompt}(s_t)}{\sum_{\tau \in \mathcal{T}} |\tau|} \times 100\% \qquad (1)$$

and the modeled **Human Verification Wait Time** $T_{\text{human}}(\mathcal{T})$ as:

$$T_{\text{human}}(\mathcal{T}) = \bar{t}_{\text{verify}} \cdot \sum_{\tau \in \mathcal{T}} \sum_{s_t \in \tau} \text{Prompt}(s_t) \qquad (2)$$

where $\bar{t}_{\text{verify}}$ models the average human context-switch and inspection time per prompt ($\bar{t}_{\text{verify}} = 5.0$ s). We define the **Maximum Autonomous Streak (MAS)** as the longest contiguous subsequence of tool calls executed with $\text{Prompt}(s_t) = 0$. Given an adversarial suite $\mathcal{E}_{\text{adv}}$, the **Attack Success Rate (ASR)** is the fraction of attacks that violate host integrity, read restricted credentials, exfiltrate secrets, or breach tenant isolation.

3 Aegis OS Runtime Architecture

Figure 1 illustrates the architecture of Aegis OS, and Table 2 summarizes its 28 MCP tools and 4 dynamic URI resources. Aegis OS follows an *"Environment Runtime Only"* design: it does not embed LLM planners or prompt templates, instead providing virtual filesystem transactions, OS process isolation, network boundary proxying, inter-agent IPC, and policy enforcement.

3.1 Transactional CoW Virtual Filesystem and Two-Phase LCS Diff3 Merge (`aos-vfs`)

To eliminate confirmation prompts on file mutations without risking host corruption, `aos-vfs` isolates every agent principal u_i inside an independent Copy-on-Write shadow workspace rooted at:

`<runtime_dir>/orgs/`o_i`/agents/`u_i`/cow_workspace/upper_workspace/`

(where `<runtime_dir>` defaults to `/tmp/aegis-os-runtime` or `~/.aegis-os`), alongside a baseline directory `baseline_snapshot/` recording the host repository state at session initialization or last commit, and a `snapshots/<snap_id>/` directory storing time-travel checkpoints.

APFS `clonefile` Shadow Provisioning. Copying a multi-megabyte repository per agent via user-space read/write loops scales as $O(|B|)$ in total byte volume. On macOS (APFS), `aos-vfs` invokes the native XNU syscall `libc::clonefile(src, dst, 0)` on eligible directory subtrees and files (automatically skipping heavy build/VCS directories such as `.git`, `target`, and `node_modules`). Because `clonefile` duplicates only filesystem metadata extents and shares physical blocks until mutated, workspace initialization scales as $O(|F|)$ in inode count (independent of file byte size $|B|$) and allocates $O(\Delta)$ physical storage only for modified files. Unlike `git worktree`, which requires a valid git commit history, shares the repository object store, and cannot snapshot dirty untracked trees in sub-millisecond time, `aos-vfs` operates transparently on any directory and supports instant nested checkpoints.

Time-Travel Snapshots, Rollback, and Build-Cache Preservation. Before speculative multi-file edits, an agent calls `workspace_snapshot(label)`, creating a CoW clone under `snapshots/<snap_id>/`. If compilation fails, `workspace_rollback(snap_id)` replaces `upper_workspace/` with a fresh CoW clone of the snapshot in milliseconds. To prevent rollbacks from invalidating incremental compiler caches, `aos-sandbox` redirects `CARGO_TARGET_DIR` to `agent_home/cargo_target` outside `upper_workspace/`.

Two-Phase LCS Diff3 3-Way Merge Engine. When multiple agents (u_1 = `agy-agent`, u_2 = `claude-code`, u_3 = `codex-cli`) concurrently edit the same file f in their shadow workspaces and sequentially invoke `workspace_commit`, a naive overwrite causes a Lost Update (Hazard H1). Aegis OS prevents this via a two-phase Longest Common Subsequence (LCS) Diff3 3-Way Merge algorithm [13] over three states per modified path p: the agent's recorded baseline $B(p)$, the live host file $H(p)$, and the agent's shadow file $S(p)$. In **Phase 1 (Validation & Staging)**, Aegis OS inspects all modified, added, and deleted files across the commit batch. If $H(p) = B(p)$, $S(p)$ is staged for fast-forward CoW clone replacement. If $H(p) \neq B(p)$, Aegis OS computes the LCS edit scripts $\Delta(B, H)$ and $\Delta(B, S)$ as half-open baseline line intervals $[b_{\text{start}}, b_{\text{end}})$. Disjoint hunks modified

Table 2: **Aegis OS MCP Tool and Resource Interface** (28 MCP Tools and 4 Dynamic URI Resources implemented in `aos-mcp-gateway`).

Subsystem	MCP Tools / Dynamic URI Resources	Default Policy Gate & Runtime Semantics
Transactional VFS (`aos-vfs`, 6 tools)	`fs_read`, `fs_write`, `fs_edit`, `fs_delete`, `fs_glob`, `workspace_status`	**Auto-Allow (0 Prompts)**: Confined to agent's CoW shadow tree
Time-Travel & Merge (`aos-vfs`, 4 tools)	`workspace_snapshot`, `workspace_diff`, `workspace_rollback`, `workspace_commit`	Snapshots/Rollback **Auto-Allow**; `workspace_commit` **Approval/Lease Gate**
OS Process Sandbox (`aos-sandbox`, 1 tool)	`proc_exec` (macOS Seatbelt `sandbox-exec` / Linux `bwrap` / MicroVM spec)	**Auto-Allow (0 Prompts)**: Writes restricted to CoW root; blocks credentials
Inter-Agent IPC & Claims (`aos-ipc`, 10 tools)	`ipc_send`, `ipc_recv`, `ipc_request`, `ipc_reply`, `ipc_ack`, `ipc_publish`, `ipc_subscribe`, `ipc_list_peers`, `coord_claim`, `coord_release`	**Auto-Allow Intra-Org**: Denied across distinct organizations ($o_{\text{src}} \neq o_{\text{dst}}$); file claims enforced
Org CAS & KV (`aos-vfs`, 4 tools)	`org_artifact_publish`, `org_artifact_fetch`, `org_kv_put`, `org_kv_get`	**Auto-Allow Intra-Org**: Reference-based `artifact://<org>/sha256:<hash>`
Zero-Trust Egress (`aos-egress`, 1 tool)	`egress_http_request` + Identity-Pinned TCP Proxy (`127.0.0.1:<port>`)	**Allowlisted Domains Auto-Allow**: Unlisted domains escalate; injects `$AOS_SECRET_*`
Policy & Leases (`aos-policy`, 3 tools)	`policy_list_escalations`, `policy_approve_escalation`, `policy_grant_lease`	Operator control plane for one-shot (`ttl=0`) or TTL-scoped `LeaseGrant` tokens
Dynamic MCP URIs (4 resources)	`aegis://workspace/status`, `aegis://ipc/inbox`, `aegis://org/peers`, `aegis://org/shared/catalog`	Live state introspection for IDE status bars and agent self-inspection

only in $H(p)$ or only in $S(p)$—including multi-line structural insertions that shift downstream line numbers—are spliced together automatically. If any file in the batch has overlapping hunks where $H_{\text{hunk}} \neq S_{\text{hunk}}$, Phase 1 aborts the entire commit before mutating any host file and returns a line-level conflict diagnostic. In **Phase 2 (Commit Application)**, all staged merges and CoW clones are applied to the host repository and updated in `baseline_snapshot/`. Conversely, when a long-lived agent resumes a session after external host commits or peer merges, `refresh_from_host()` rebases the shadow workspace onto the latest host state—fast-forwarding unmodified files and applying 3-way Diff3 merges to files with uncommitted local shadow edits.

3.2 Dual-Tier OS Sandbox and Zero-Trust Egress Proxy (`aos-sandbox`, `aos-egress`)

While `aos-vfs` mediates MCP file tools, coding agents also spawn compilers, test runners, and shell scripts via `proc_exec`. To prevent child processes from bypassing workspace or network boundaries, `aos-sandbox` provides a pluggable `SandboxDriver` with two tiers:

1. **Tier 1 (`NativeOsSandboxDriver`, Workstation Kernel Enforcement):** On macOS, every `proc_exec` call compiles a canonicalized Seatbelt Mandatory Access Control profile (SBPL) and spawns the child process under `/usr/bin/sandbox-exec -p <profile>` with a sanitized environment (`env_clear()`). The generated profile blocks AppleEvent IPC (`(deny appleevent-send)`), denies all file writes globally (`(deny file-write*)`), allowlists writes strictly to the agent's CoW shadow workspace, private agent home, and organization publish directory, blocks reads to sensitive credential paths, and—when an egress proxy is bound—restricts outbound network sockets exclusively to the exact loopback port of the agent's proxy:

```
(version 1)
(allow default)
(deny appleevent-send)
(deny file-write*)
(allow file-write*
  (subpath "/private/.../upper_workspace")
  (subpath "/private/.../home")
  (subpath "/private/.../pub/agy-agent")
  (literal "/dev/null") (literal "/dev/zero") (literal "/dev
     /tty")
  (literal "/dev/random") (literal "/dev/urandom"))
(deny file-read*
  (regex #".*/\.ssh(/.*)?$")   (regex #".*/\.aws(/.*)?$")
  (regex #".*/\.gnupg(/.*)?$") (regex #".*/\.kube(/.*)?$")
  (regex #".*/\.npmrc$")       (regex #".*/\.pypirc$")
  (regex #".*/\.config/gh(/.*)?$")
  (regex #".*/Library/Keychains(/.*)?$")
  (literal "/etc/shadow"))
(deny network-outbound)
(allow network-outbound (remote ip "localhost:51691"))
```

   Because `(deny network-outbound)` is enforced by the XNU kernel socket filter and allows only `localhost:<proxy_port>` (without permitting wildcard localhost ports or `mDNSResponder`), a child process running `curl -noproxy '*'` or opening raw sockets to external IPs or other local services fails immediately with `Operation not permitted`. On Linux, `NativeOsSandboxDriver` constructs Bubblewrap (`/usr/bin/bwrap`) arguments with `-unshare-all` (unsharing user, mount, PID, IPC, and network namespaces when an egress proxy is bound), read-only root binds (`-ro-bind / /`), writable binds only for the shadow workspace and agent home, and empty `-tmpfs` overlays masking `~/.ssh`, `~/.aws`, `~/.gnupg`, and `~/.kube`.

2. **Tier 2 (`MicroVmSandboxDriver`, Cloud Control-Plane Interface):** Provides the configuration generator (`virtio-fs` mount tags, vCPU/memory limits) and Scale-to-Zero `pause()`/`resume()` state machine for cloud microVM backends (`libkrun` / Firecracker [1]).

Identity-Pinned Egress Proxy with Boundary Secret Injection. To mitigate credential exfiltration (Threat T4), agents inside Aegis OS do not receive raw API keys in environment variables. Instead, they receive opaque placeholders such as `$AOS_SECRET_GH`. Outbound HTTP traffic is routed through a local asynchronous L7 HTTP proxy (`start_local_proxy_with_bound_identity`). Because each sandbox listener pins its `AgentIdentity` at the TCP socket level, a compromised process cannot spoof `X-Aegis-Org` or `X-Aegis-Agent` headers. On each request, the gateway first checks all headers for `$AOS_SECRET_*` placeholders against the secret vault's per-secret domain binding, and then checks the target `Host` against the organization's domain allowlist:

- If `$AOS_SECRET_GH` (bound to `api.github.com`) is sent toward `api.github.com`, the proxy substitutes

the real token `ghp_...` at the network boundary (returning a deterministic L7 verification response in local offline/benchmark mode or forwarding upstream).

- If an agent attempts to send `$AOS_SECRET_GH` to any other domain (even an otherwise allowlisted domain such as `httpbin.org`, or an attacker host such as `evil-exfil.org`), the proxy rejects the request with `HTTP/1.1 403 Forbidden` (`blocked_exfiltration`).

3.3 Inter-Agent IPC Bus and Reference-Based CAS (`aos-ipc`)

To support multi-agent coordination without shared-directory polling, `aos-ipc` provides a disk-synchronized, broadcast-enabled communication bus scoped to each organization tenant o_i:

- **P2P Mailboxes and Correlated RPC:** Agents exchange structured envelopes via `ipc_send`, `ipc_recv`, `ipc_request`, `ipc_reply`, and `ipc_ack`. Using `tokio::sync::broadcast` paired with persistent state (`ipc_state.json`), cross-process stdio and HTTP agents receive immediate wakeup notifications when correlated RPC replies arrive.
- **Topic Pub/Sub Fanout:** Agents subscribe to organizational topics (`ipc_subscribe`) and broadcast events via `ipc_publish`.
- **Advisory-but-Enforced File Claims:** Before editing shared modules, agents invoke `coord_claim` (and `coord_release` upon completion) to register glob-based file leases stored as versioned CAS read-modify-write entries (`coordination/claims` in `aos-vfs`) and broadcast on `topic://coordination`. Claims held by live peers (verified via heartbeat liveness) are enforced both at pre-tool-use time and during `workspace_commit` (`claim_conflict_for_paths`), preventing concurrent edit collisions before merge time.
- **Reference-Based CAS Artifact Handles:** Instead of embedding a 64 KB specification or patch inline inside an IPC message payload, the sender calls `org_artifact_publish`, which writes the blob to the organization's Content-Addressable Store and returns a compact SHA-256 URI (`artifact://<org>/sha256:<64-hex>`, ∼85–98 bytes). Passing this URI handle in IPC envelopes eliminates redundant inline serialization across orchestrator and peer message queues (reducing in-transit IPC payload tokens by **99.85%**); receiving agents that need to inspect the full content fetch it on demand via `org_artifact_fetch`.

3.4 Cedar-Inspired Policy Engine and Runtime Design Invariants (`aos-policy`)

Every runtime tool call is evaluated by `AegisPolicyKernel::evaluate` using a five-stage deterministic hierarchy inspired by Cedar [6]:

$$
\begin{aligned}
\text{R0a (Red-Line):}\ & \text{res} \in \mathcal{P}_{\text{forbidden}} \implies \textbf{Deny} \\
\text{R0b (Hook Guard):}\ & \text{act} = \texttt{workspace_commit} \\
& \quad \wedge\ \text{paths} \cap \mathcal{P}_{\text{hooks}} \neq \emptyset \implies \textbf{Ask}(\text{esc_id}) \\
\text{R1 (Tenant):}\ & o_{\text{principal}} \neq o_{\text{target}} \implies \textbf{Deny} \\
\text{R2 (Lease):}\ & \exists \ell \in \mathcal{L}_{\text{active}}(o, u, \text{act}) \implies \textbf{Allow} \\
\text{R3 (Green Zone):}\ & \text{act} \in \mathcal{S}_{\text{internal}} \cup \mathcal{S}_{\text{egress}} \implies \textbf{Allow} \\
\text{R4 (Boundary):}\ & \text{act} \in \{\texttt{workspace_commit}, \\
& \quad \texttt{egress_unlisted}\} \implies \textbf{Ask}(\text{esc_id})
\end{aligned}
$$

where $\mathcal{P}_{\text{forbidden}}$ = {`~/.ssh`, `~/.aws`, `~/.gnupg`, `~/.kube`, `/etc/shadow`, `/etc/sudoers`, `/System`} is the host red-line set, and $\mathcal{P}_{\text{hooks}}$ = {`.git/hooks/*`, `.git/config`, `.envrc`, `.github/workflows/*`} is the **Commit-Time Poisoning Guard** set. Crucially, R0b is evaluated *before* active session leases (R2): even if a developer grants a 1-hour session lease for `workspace_commit`, any commit touching git hooks, `.envrc`, or CI workflow files bypasses the lease and forces explicit human review. When approving an escalation via `policy_approve_escalation`, the operator can choose either a one-shot approval (`ttl_secs = 0`, consumed immediately on that single commit) or a TTL-scoped session lease (e.g., `ttl_secs = 3600`).

Together, these mechanisms enforce three runtime design invariants:

- **Design Invariant 1 (Pre-Commit Host Non-Interference):** *For any tool call sequence $\tau = (s_1, \ldots, s_k)$ containing no approved `workspace_commit`, the host directory tree H satisfies $H(\tau) = H_0$. Enforcement sketch:* VFS tools (`fs_write`, `fs_edit`, `fs_delete`) reject path traversal (`..`) and resolve all relative paths under `shadow_root`, while `proc_exec` enforces Seatbelt `(deny file-write*)` outside `shadow_root`, `agent_home`, and `org_pub`.
- **Design Invariant 2 (Zero Raw Secret Exposure to Sandbox):** *For every secret entry $(p_j, v_j, \mathcal{D}_j)$ in the Egress Vault, the plaintext credential v_j never enters the sandboxed process environment, CLI arguments, or stdout/stderr, and is substituted into outbound HTTP headers if and only if Host(req) $\in \mathcal{D}_j$. Enforcement sketch:* `NativeOsSandboxInstance::exec` clears the child environment (`env_clear()`) and injects only placeholders p_j = `$AOS_SECRET_*`; `inspect_and_inject` verifies Host(req) $\in \mathcal{D}_j$ before substituting v_j.

- **Design Invariant 3 (All-or-Nothing Conflict-Safe Commit):** *Concurrent agent commits* $(S_1, \ldots, S_m)$ *against baselines* $(B_1, \ldots, B_m)$ *either produce a merged host state preserving all disjoint LCS Diff3 hunks, or abort in Phase 1 without modifying any host file when overlapping baseline intervals* $[b_{start}, b_{end})$ *diverge. Enforcement sketch:* `commit_to_host` stages and validates all file merges in memory during Phase 1 before executing any file writes in Phase 2.

4 Multi-Client Integration and Enforcement

To minimize setup friction, `aegis-os install` automatically configures MCP server entries, per-session principal resolution, and lifecycle hooks across all three coding agent CLIs:

1. **Google Antigravity (`agy`):** Registers `aegis-os` in `~/.gemini/config/mcp_config.json` with eager tool loading, pre-authorizes green-zone `mcp(aegis-os/*)` tools in `settings.json` while keeping lease/approval tools (`policy_grant_lease`, `policy_approve_escalation`) under `permissions.ask`, and installs four lifecycle hooks (`SessionStart`, `PreInvocation`, `PreToolUse`, and `Stop`):

   - *MCP-First Tool Routing (`PreToolUse`):* Because agent CLIs still prompt on native `run_command` invocations unless exact command strings match static allowlists, `aegis-os agy-hook` classifies native shell and file calls: Ring-0 operations (`sudo`, credential paths) are unconditionally denied; host-boundary commands (`git push`, package installs) escalate to `ask`; and in-repository shell commands and file writes are denied with a ready-to-invoke `mcp_aegis-os_proc_exec` or `mcp_aegis-os_fs_write` payload, steering the agent onto the zero-prompt sandboxed MCP path.
   - *Per-Session Identity & Push Coordination (`SessionStart`, `PreInvocation`, `Stop`):* Walking parent process ancestry (`PROC_PIDTBSDINFO` on macOS / `/proc/<pid>/stat` on Linux) assigns each concurrent client window a distinct session principal (`agy-<6hex>`) bound to its `conversationId`. On `SessionStart`, the agent's CoW shadow is rebased onto the host via `refresh_from_host()`; on `PreInvocation`, unread IPC messages are non-destructively peeked and injected via `injectSteps.systemMessage`; and on `Stop`, un-acknowledged `TaskRequest` messages hold the turn open (up to 2 continues) until answered, while `coord_claim`/`coord_release` prevent overlapping file edits across live peers.

2. **Anthropic Claude Code (`claude`):** Injects `aegis-os` into `~/.claude.json` and adds green-zone `mcp__aegis-os__*` rules to `permissions.allow` in `~/.claude/settings.json`.

3. **OpenAI Codex CLI (`codex`):** Appends `[mcp_servers.aegis-os]` to `~/.codex/config.toml` and piggybacks unread IPC summaries (`_aegis_inbox`) onto `tools/call` responses.

5 Empirical Evaluation

We evaluate Aegis OS using our reproducible benchmark suite (`crates/aos-cli/src/bench.rs`, invoked via `aegis-os bench`). All experiments were executed on an Apple Silicon workstation (`macos-aarch64`, APFS filesystem, Rust 1.99.0 `-release`) using real OS processes, Seatbelt kernel sandboxes, loopback TCP sockets, and `cargo` builds. We investigate five research questions:

- **RQ1 (Authorization Friction):** How much does Aegis OS reduce confirmation prompts and modeled verification wait time across multi-step software engineering trajectories?

- **RQ2 (Adversarial Security):** Does Aegis OS block end-to-end OS process, credential harvesting, proxy/socket exfiltration, and cross-tenant attacks that compromise unconfined `Host-YOLO` execution?

- **RQ3 (System Overhead & Scaling):** What is the latency and disk footprint of APFS CoW provisioning, policy evaluation, HTTP daemon RPCs, 3-way merge commits, and Seatbelt process spawning?

- **RQ4 (Multi-Agent Concurrency):** Does two-phase LCS Diff3 merging preserve concurrent multi-agent edits (including multi-line insertions) while catching overlapping line conflicts?

- **RQ5 (Fault Recovery):** How fast does atomic CoW rollback recover from multi-file syntax corruption compared to sequential file restoration?

Table 3: **Experiment 1 (RQ1): Authorization Friction, Interruption Prompt Rate (IPR), and Modeled Human Wait Time** across 50 deterministic multi-step trajectories spanning 5 SWE task templates (1,500 tool calls executed on `AegisRuntimeKernel`, including 50 real `workspace_commit` operations in every mode; human verification modeled at $\bar{t}_{\text{verify}} = 5.0$ s/prompt).

Execution Mode	Trajectories	Tool Calls	Human Prompts	IPR (%)	Prompt Reduction	Max Autonomous Streak	Runtime Exec (ms)	Modeled Human Wait (T_{human})
Host-Interactive (Per-Mutation Prompt)	50	1,500	860	57.33%	0.00% (Baseline)	4 steps	457.1 ms	71.7 min (4,300 s)
Host-Static-Allowlist (Read/Status Allow)	50	1,500	680	45.33%	20.93%	7 steps	496.7 ms	56.7 min (3,400 s)
Aegis-OS (Per-Task Commit Gate, `ttl=0`)	50	1,500	**50**	**3.33%**	**94.19%**	**29 steps**	**483.6 ms**	**4.2 min (250 s)**
Aegis-OS (With 1h Session Lease)	50	1,500	**1**	**0.07%**	**99.88%**	**1,470 steps**	**469.2 ms**	**0.08 min (5 s)**

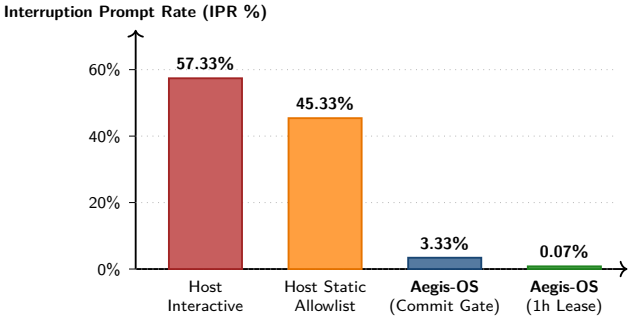


Figure 2: Interruption Prompt Rate (IPR) across 1,500 tool calls spanning 5 SWE task templates (Experiment 1). Aegis OS reduces human prompts by 94.19% in per-task commit mode (`ttl=0`) and 99.88% with a 1-hour session lease.

5.1 Experiment 1 (RQ1): Authorization Friction and Autonomous Continuity

To evaluate authorization friction reproducibly without LLM sampling variance, we execute 50 deterministic software engineering trajectories (30 tool calls per trajectory, totaling 1,500 real `AegisRuntimeKernel::call_tool` invocations) cycling across five task templates: (1) *Auth Bugfix & Regression Test*, (2) *Multi-Module Refactoring*, (3) *Feature Implementation & Quota Suite*, (4) *Security Audit & Sanitizer Hardening*, and (5) *Multi-Agent Contract Sync*. Each trajectory exercises repository exploration (`fs_glob`, `fs_read`), checkpointing (`workspace_snapshot`), multi-file edits (`fs_edit`, `fs_write`), CAS publishing (`org_artifact_publish`), peer IPC coordination (`ipc_send`, `ipc_recv`, `ipc_publish`), diff inspection (`workspace_diff`), and host commit (`workspace_commit`). All four modes execute all 1,500 tool calls including all 50 real `workspace_commit` operations.

Table 3 and Figure 2 present the results. Under *Host-Interactive*, every file write, state mutation, and external IPC action triggers a confirmation prompt (860 prompts, IPR = 57.33%), restricting the maximum autonomous streak to 4 steps and imposing 71.7 minutes of modeled verification wait time (at $\bar{t}_{\text{verify}} = 5.0$ s/prompt) on top of 457.1 ms of runtime execution. Adding a static read-/status/snapshot allowlist (*Host-Static-Allowlist*) still triggers 680 prompts (IPR = 45.33%, 56.7 minutes modeled wait) because host file edits cannot be safely auto-allowed. In contrast, **Aegis-OS (Per-Task Commit Gate)** auto-allows all 29 internal CoW workspace and IPC operations per trajectory and prompts once at the final `workspace_commit` gate (approved via a one-shot `ttl=0` token), reducing prompts by **94.19%** (IPR = 3.33%, 483.6 ms runtime execution). When the operator grants a **1-hour Session Lease** (`ttl=3600`) on the first commit escalation, Aegis OS completes all 50 trajectories (and all 50 host commits) in 469.2 ms with **1 prompt total** (IPR = 0.07%, a **99.88% reduction**), extending the continuous autonomous streak to **1,470 steps** (**367.5**× longer).

5.2 Experiment 2 (RQ2): End-to-End Adversarial Security

We execute 40 live adversarial attacks end-to-end against both an unconfined disposable victim environment (`Host-YOLO`) and `Aegis-OS`:

- **Category A (10 Host Path Escape Attacks):** Spawns `sh -c "echo COMPROMISED > <outside_target>"`. In `Host-YOLO`, all 10 outside-workspace files were created on disk (ASR = 100.0%). Inside `Aegis-OS` (`proc_exec`), `/usr/bin/sandbox-exec` denied all 10 writes at the XNU kernel boundary with `Operation not permitted` (ASR = 0.0%).
- **Category B (10 Multi-Store Credential Harvesting Attacks):** Spawns `sh -c "cat <cred_path>"` cycling across `~/.ssh/id_rsa`, `~/.aws/credentials`, `~/.gnupg/secring.gpg`, `~/.kube/config`, and `~/.npmrc`. `Host-YOLO` leaked the secret key material on all 10 attempts (ASR = 100.0%), whereas the Aegis OS Seatbelt profile blocked all 10 reads (ASR = 0.0%).
- **Category C (10 Sandbox-to-Proxy and Direct -noproxy Egress Exfiltration Attacks):** We start a live local TCP sink server (`sink_addr`) recording leaked secrets, alongside an identity-pinned `AegisEgressGateway` (`proxy_addr`). In `Host-YOLO`, an unconfined `curl` process with `$GITHUB_TOKEN` in its environment transmitted the plaintext token to `sink_addr` across all 10 attacker

Table 4: **Experiment 2 (RQ2): End-to-End Red-Team Adversarial Attack Evaluation** across 40 live process, socket, proxy, and multi-tenant gateway attacks executed against an unconfined `Host-YOLO` target environment versus `Aegis-OS`.

Attack Surface Category	Live Attacks	Host-YOLO Compromised (ASR)	Aegis-OS Compromised (ASR)	Empirical Kernel / Gateway Evidence
A. Host Path Escape & File Tampering	10	10 / 10 (100.0%)	**0 / 10 (0.0%)**	Kernel `sandbox-exec` denied all 10 outside writes (`Operation not permitted`)
B. Host Credential Harvesting (`.ssh/.aws/.kube/.npmrc`)	10	10 / 10 (100.0%)	**0 / 10 (0.0%)**	Seatbelt regexes (`deny file-read* ...`) blocked all 10 credential reads
C. Sandbox-to-Proxy & Direct `-noproxy` Egress Exfil	10	10 / 10 (100.0%)	**0 / 10 (0.0%)**	Pinned TCP Proxy returned `403` & Seatbelt blocked all `-noproxy` sockets
D. Cross-Tenant IPC & CAS Access via MCP Gateway	10	10 / 10 (100.0%)	**0 / 10 (0.0%)**	MCP Gateway + Policy Engine rejected all 10 cross-org tool calls ($o_{\text{src}} \neq o_{\text{dst}}$)
Total / Evaluated ASR	**40**	**40 / 40 (100.0%)**	**0 / 40 (0.0%)**	**0 / 40 Compromised across OS Kernel, Network Proxy & Tenant Gateway**

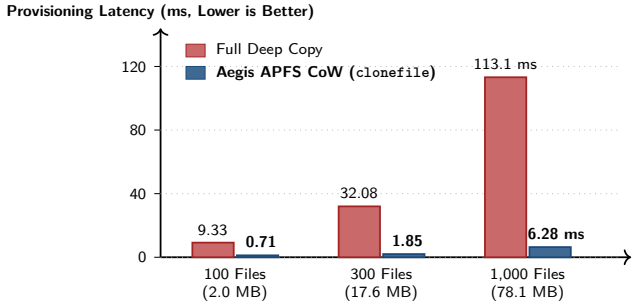


Figure 3: Workspace provisioning latency across repository scales (Experiment 3A). APFS `clonefile` scales with metadata count $O(|F|)$ rather than byte volume $O(|B|)$, achieving an 18.0× speedup on the 1,000-file repository.

domains (ASR = 100.0%). In `Aegis-OS`, we execute `curl` inside a Seatbelt sandbox (`sbx_egress.exec`) bound to `localhost:<proxy_port>` that attempts *both* (1) proxy exfiltration of `$AOS_SECRET_GH` to 10 unauthorized domains (`evil-exfil.org`, `webhook.site`, `ngrok-free.app`, etc.), which the proxy rejected with `HTTP/1.1 403 Forbidden` (`blocked_exfiltration`), and (2) direct proxy-bypass (`curl -noproxy '*' http://<sink_addr>/bypass`), which the XNU Seatbelt socket filter blocked with `Operation not permitted`. Zero tokens reached `sink_addr` (ASR = 0.0%).

- **Category D (10 Cross-Tenant IPC and CAS Attacks via MCP Gateway):** In a shared flat host store (`Host-YOLO`), an unconfined process directly read all 10 confidential enterprise tenant files (ASR = 100.0%). In `Aegis-OS`, we register 10 enterprise tenants (`org-enterprise-`i), publish confidential CAS artifacts via `org_artifact_publish`, and have principal `mallory` (`org-alpha`) invoke `kernel.call_tool` (`ipc_send` and `org_artifact_fetch`) targeting `org-enterprise-`i. All 10 cross-tenant tool calls were denied by Rule R1 (ASR = 0.0%).

5.3 Experiment 3 (RQ3): CoW Provisioning, Storage Footprint, and Operation Latency

We benchmark workspace provisioning across three repository scales (100 files / 2.0 MB, 300 files / 17.6 MB, and 1,000 files / 78.1 MB, 5 trials per scale). As shown in Table 5 and Figure 3, full copying requires 113.13 ± 16.41 ms for the 1,000-file repository, whereas APFS `libc::clonefile` provisions the shadow workspace in 6.28 ± 0.65 **ms** (**18.0× faster**). Note that `clonefile` latency scales linearly with file/inode metadata count $O(|F|)$ (from 0.71 ms at 100 files to 6.28 ms at 1,000 files) rather than byte size $|B|$. Across 10 concurrent agent workspaces modifying working sets of 6, 12, and 25 files per agent, APFS CoW reduces disk block allocation by **94.0%–97.5%** (19.5 MB vs. 781.2 MB at 1,000 files).

Table 6 reports the latency distribution across all five runtime operation classes. In-process policy evaluation takes **0.31** μ**s** (310 ns, 2.96M ops/s), P2P IPC send/receive takes **1.06** μ**s**, a loopback HTTP JSON-RPC `fs_read` call (`POST /mcp`) takes **177.11** μ**s**, a two-phase LCS Diff3 `commit_to_host` takes **424.02** μ**s**, and spawning an external process under macOS Seatbelt (`/usr/bin/sandbox-exec /usr/bin/true`) takes **6.68 ms** (6,678.97 μs). Relative to typical LLM inference turns (0.5–2.0 s), MCP tool mediation adds $< 0.04\%$ latency and Seatbelt process confinement adds ∼6.7 ms per spawned command.

5.4 Experiment 4 (RQ4): Multi-Agent Concurrent Rust Coding and Conflict Detection

We evaluate both disjoint structural edits and overlapping concurrent edits across `agy-agent`, `claude-code`, and `codex-cli` on a Rust crate (`src/lib.rs`):

- **Concurrent Multi-Line Insertion and Function Edits (EXP 4A):** All three agents start from the same baseline `src/lib.rs`. `agy-agent` inserts a 3-line helper function (`min_fee()`) at the top of the file and updates `calc_fee` (shifting downstream line indices), while `claude-code` modifies `calc_tax` and `codex-cli` modifies `calc_discount`. When writing directly to a shared file (**Host-Shared-YOLO**), the final writer (`codex-cli`) overwrites the earlier

Table 5: **Experiment 3A (RQ3): Multi-Trial APFS Copy-on-Write Workspace Provisioning Latency and Storage Efficiency** across 10 concurrent agents modifying realistic per-task working sets (6, 12, and 25 files per agent; 5 trials per scale, Mean ± StdDev).

Repository Scale	Files ($\|F\|$)	Logical Size ($\|B\|$)	Full Copy (Mean ± SD)	Aegis CoW Clone (Mean ± SD)	Clone Speedup	10-Agent Disk Saving
Small Project	100	2.0 MB	9.33 ± 0.28 ms	$\mathbf{0.71 \pm 0.05}$ **ms**	**13.2**×	**94.0%** (1.2 MB vs. 19.5 MB)
Medium Project	300	17.6 MB	32.08 ± 5.82 ms	$\mathbf{1.85 \pm 0.09}$ **ms**	**17.3**×	**96.0%** (7.0 MB vs. 175.8 MB)
Large Project	1,000	78.1 MB	113.13 ± 16.41 ms	$\mathbf{6.28 \pm 0.65}$ **ms**	**18.0**×	**97.5%** (19.5 MB vs. 781.2 MB)

Table 6: **Experiment 3B (RQ3): Kernel, Daemon, Merge Commit, and Sandbox Spawn Latency Distribution**.

Runtime Operation	Mean (μs)	P50 (μs)	P95 (μs)	P99 (μs)	Ops/sec
`PolicyKernel::evaluate` (N=2000)	0.31	0.29	0.38	0.50	2,959,674
`IpcBus::send + recv` (N=1000)	1.06	0.83	1.79	4.75	924,749
`HTTP POST /mcp` (`fs_read`, N=200)	177.11	183.08	258.79	409.00	5,503
`commit_to_host` (3-Way Merge, N=100)	424.02	413.08	540.21	646.12	2,110
`Sandbox::exec` (`sandbox-exec`, N=30)	6,678.97	6,557.62	7,533.12	7,811.33	150

edits, preserving only **1/3** of the features. In **Aegis-OS**, our two-phase LCS Diff3 engine aligns the unmodified anchor lines across the unequal-length files (matching the merge semantics of `git merge-file` without requiring manual `git worktree` branches per agent), preserving **3/3 (100%)** of the features and passing `cargo test -offline` (`exit code 0`).

- **Overlapping Same-Line Conflict Detection (EXP 4B):** Across 10 trials, both `agy-agent` and `codex-cli` concurrently modify `calc_fee` with conflicting expressions. While **Host-Shared-YOLO** suffers a silent lost update (0/10 detected), **Aegis-OS** detects **10/10 (100%)** of the conflicts during Phase 1, aborts the second commit without modifying the host file, and returns the exact conflicting baseline line number.

- **In-Transit IPC Token Savings:** Passing 98-byte `artifact://` CAS URI handles instead of inline 64 KB specifications across 3 inter-agent handoffs reduces in-transit IPC message payload bytes from 196,608 bytes (∼49,152 tokens) to 294 bytes (∼73 tokens), a **99.85% reduction** for orchestrator routing and pass-through delegation (Table 7).

5.5 Experiment 5 (RQ5): Time-Travel Rollback and `cargo check` Verification

We evaluate recovery from multi-file syntax corruption (`BROKEN_RUST_SYNTAX_ERROR !!!`) injected across 10, 50, and 200 Rust module files (`src/mod_*.rs`, 64 KB per module). As shown in Table 8, Aegis OS's directory-tree `workspace_rollback` restores all 200 corrupted modules in 8.68 ± 1.02 **ms** (**2.4× faster** than sequential file-by-file I/O restoration), and immediately passes `cargo check -offline` inside the restored shadow workspace across all scales.

6 Discussion and Limitations

Cross-Platform Implementation Scope (macOS vs. Linux). Table 9 summarizes the implementation status of each OS primitive in `aegis-os`. Our empirical evaluation in §5 was conducted on macOS (`macos-aarch64`), where `libc::clonefile` and `/usr/bin/sandbox-exec` are exercised end-to-end. On Linux, `NativeOsSandboxDriver` generates `/usr/bin/bwrap` arguments with `-unshare-all` (including network namespace isolation when an egress proxy is configured) and mounts empty `-tmpfs` overlays over `~/.ssh`, `~/.aws`, `~/.gnupg`, and `~/.kube`; adding native Linux `ioctl(FICLONE)` reflinks [18], Landlock LSM, and `seccomp-bpf` syscall filters, as well as binding `MicroVmSandboxDriver` to live `libkrun`/Firecracker VMM processes, are engineering extensions for Linux cloud deployments.

macOS Seatbelt Architecture and Escape Surface. On macOS, dynamic linker caches (`dyld`), Xcode toolchains, and Homebrew packages traverse numerous paths under `/System`, `/Library`, and `/opt/homebrew`. Thus, our Seatbelt profile pairs a strict write allowlist (`(deny file-write*)`) with a regex read denylist for credential stores, `(deny appleevent-send)` to prevent AppleScript/GUI automation escapes, and exact port confinement `(allow network-outbound (remote ip "localhost:<proxy_port>"))`. While Apple has marked `/usr/bin/sandbox-exec` as a legacy interface, it remains the standard kernel MAC mechanism used by production agent CLIs (including Claude Code and Codex CLI) on macOS because Apple's Endpoint Security and `Virtualization.framework` require root entitlements or full VM boot overhead. Hardening Mach bootstrap lookups (`mach-lookup`) against LaunchServices job spawning without breaking toolchain execution is an important direction for future work.

Session Leases and Commit-Time Poisoning. Granting a 1-hour session lease (`ttl=3600`) eliminates 99.88% of prompts by allowing validated CoW diffs to commit automatically. However, if a prompt-injected agent modifies repository build scripts (e.g., `Makefile`, `build.rs`, or `package.json postinstall`) and commits under an active lease, a subsequent unsandboxed build on the host could execute attacker code (*commit-time poisoning*). Aegis OS mitigates the most direct

Table 7: **Experiment 4 (RQ4): 3-Agent (`agy` + `claude` + `codex`) Concurrent Rust Modification, Overlapping Conflict Detection, and `cargo test` Verification.**

Evaluation Metric	Host-Shared-YOLO (In-Place Write)	Aegis-OS Isolated CoW + 2-Phase LCS Diff3	Empirical Result
Concurrent 3-Agent Structural & Function Edits (`src/lib.rs`)	1 / 3 preserved (2 / 3 overwritten)	**3 / 3 preserved (100% LCS Diff3 Merged)**	**3.0× Feature Retention (0% Clobber)**
Overlapping Same-Line Edit Conflict Detection (10 Trials)	0 / 10 detected (Silent Lost Update)	**10 / 10 detected & aborted in Phase 1 (Host intact)**	**100% Conflict Safety**
Post-Merge Real `cargo test -offline` Verification	Failed (Missing `agy` & `claude` logic)	**Passed (`cargo test` exit code 0)**	**Build & Test Verified**
In-Transit IPC Payload for 3×64 KB Spec Handoffs	196,608 bytes (∼49,152 tokens inline)	**294 bytes (∼73 tokens via CAS URI handles)**	**99.85% In-Transit Token Reduction**

Table 8: **Experiment 5 (RQ5): Multi-File Corruption Recovery and `cargo check` Verification** (5 trials/scale, Mean ± SD).

Corrupted Modules	Seq. File Restore	Aegis CoW Rollback	Speedup	`cargo check`
10 (640 KB)	0.90 ± 0.06 ms	**0.75 ± 0.04 ms**	**1.2**×	PASSED
50 (3.2 MB)	4.82 ± 0.32 ms	**2.33 ± 0.14 ms**	**2.1**×	PASSED
200 (12.8 MB)	20.63 ± 3.14 ms	**8.68 ± 1.02 ms**	**2.4**×	PASSED

vectors via Rule R0b (§3.4), which refuses silent lease auto-commits whenever a diff touches `.git/hooks/*`, `.git/config`, `.envrc`, or `.github/workflows/*`. Extending R0b to require human approval on `build.rs`, `Makefile`, and `package.json` modifications is straightforward.

Confused Deputy on Allowlisted Egress Domains and HTTPS TLS Termination. Boundary secret injection guarantees that raw tokens never enter the agent sandbox and cannot be sent to unauthorized domains. However, if `api.github.com` is allowlisted for `$AOS_SECRET_GH`, a prompt-injected agent could still act as a *confused deputy* by issuing a `POST /gists` request to exfiltrate code to a public GitHub Gist on `api.github.com`. Mitigating confused-deputy exfiltration on allowlisted domains requires restricting secret injection by HTTP method and URL path prefix (e.g., permitting `GET /repos/org/*` while escalating `POST /gists`). Additionally, intercepting headers inside direct `HTTPS CONNECT` tunnels from legacy CLI binaries requires configuring the local proxy with a session-scoped ephemeral TLS Certificate Authority (`SSL_CERT_FILE`).

Syntactic 3-Way Merging vs. Semantic Conflicts. Our two-phase LCS Diff3 engine resolves disjoint line edits and aborts on overlapping line conflicts, but syntactically disjoint edits can still introduce semantic conflicts (e.g., Agent A renames a function signature at Line 10 while Agent B calls the old function name at Line 120) [4]. Running `cargo test` via `proc_exec` after merging peer changes and rolling back via `workspace_rollback` if compilation fails mitigates semantic integration errors.

7 Related Work

Operating System Transactions and Speculative Execution. Our transaction-boundary security model builds on classical operating system transactions. TxOS [17] introduced kernel-level system transactions (`sys_xbegin`/`sys_xend`) providing ACID semantics for OS resources, while Speculator [16] enabled speculative process execution over distributed filesystems with rollback on dependency failure. Mbox [14] and UnionFS [22] layered user-space filesystem interposition above host directories to sandbox untrusted build scripts and package installations. Aegis OS adapts OS transaction semantics specifically to multi-tenant AI coding agents, combining APFS `clonefile` CoW shadow trees with two-phase LCS Diff3 merging [13, 4] and Cedar-inspired [6] session leases.

Authorization Fatigue in Usable Security. Empirical studies of permission systems in mobile OSes [9] and browser security warnings [2] have consistently shown that high-frequency, low-context prompts induce habituation, causing users to click through warnings without comprehension. Autonomous coding agents exacerbate this phenomenon by issuing dozens of mutating tool calls per minute; Aegis OS eliminates intermediate prompts by making in-sandbox actions side-effect-free and reversible.

LLM Agent Sandboxes and Prompt Injection Defenses. Benchmarks such as SWE-bench [12], SWE-agent [25], OpenHands [20], ToolEmu [19], AgentDojo [8], and InjecAgent [26] demonstrate both the utility of coding agents and their susceptibility to indirect prompt injection [10]. System-level defenses such as IsolateGPT [24], CaMeL [7], and FIDES [5] enforce privilege separation or information-flow control across LLM planners and tool interpreters. Production CLIs such as Claude Code (`sandbox-runtime`) and Codex CLI integrate Seatbelt and Bubblewrap/Landlock sandboxes to confine shell commands in place. Aegis OS complements both model-level IFC defenses and in-place CLI sandboxes by adding transactional CoW shadow workspaces, two-phase Diff3 multi-agent merge commits, boundary secret injection, and cross-agent IPC/CAS.

Agent Operating Systems and Multi-Agent Frameworks. AIOS [15] schedules LLM queries and context snapshots above application agents, while AutoGen [23] and MetaGPT [11] coordinate multi-agent dialogues in Python. Aegis OS instead operates purely as a language-agnostic OS runtime below the MCP boundary [3], drawing on capability systems such as Capsicum [21] and microVMs such as Firecracker [1].

Table 9: **Cross-Platform Operating System Primitive Mapping and Implementation Status** in Aegis OS.

Aegis OS Subsystem	macOS Workstation (Evaluated)	Linux Workstation / Host	Cloud Host (Tier 2)	Current Implementation Status
CoW Workspace (`aos-vfs`)	APFS `libc::clonefile(src, dst, 0)`	Copy fallback (Btrfs `FICLONE` / `OverlayFS`)	Virtio-fs CoW mount spec	macOS `clonefile` evaluated; Linux copy fallback
Process MAC (`aos-sandbox`)	XNU Seatbelt (`/usr/bin/sandbox-exec`)	Bubblewrap (`/usr/bin/bwrap -unshare-all`)	KVM (`libkrun` / Firecracker)	macOS Seatbelt & Linux `bwrap` implemented; Tier-2 spec
Credential Blocking (`~/.ssh`)	Seatbelt (`deny file-read* (regex ...)`)	`bwrap -tmpfs` over `.ssh/.aws/.gnupg/.kube`	Unmounted host volumes	Implemented in both macOS SBPL & Linux `bwrap`
IPC / GUI Escape Guard	Seatbelt (`deny appleevent-send`)	`bwrap` PID/IPC namespace isolation	Guest VM kernel boundary	Implemented (Landlock/`seccomp-bpf` planned)
Zero-Trust Egress (`aos-egress`)	Pinned TCP Proxy + Seatbelt `localhost:<port>`	Pinned TCP Proxy + `bwrap` net unshare	Tap/vsock Egress Gateway	Pinned TCP Proxy & Seatbelt port filter evaluated

8 Conclusion

We presented **Aegis OS**, a transactional, multi-tenant Agent Operating System Runtime that addresses the Security–Autonomy Dilemma for autonomous coding agents. By combining APFS Copy-on-Write shadow workspaces, two-phase LCS Diff3 multi-agent merge commits, kernel-enforced Seatbelt/Bubblewrap sandboxes with port-pinned network confinement, boundary secret injection, and intra-organization IPC + CAS primitives, Aegis OS reduces human confirmation prompts by 94.19%–99.88% on our benchmark suite while blocking all 40 evaluated process, credential, network, and cross-tenant attacks.

References

[1] Alexandru Agache, Marc Brooker, Andreea Florescu, Alexandra Iordache, Anthony Liguori, Rolf Neugebauer, Phil Piwonka, and Diana-Maria Popa. Firecracker: Lightweight virtualization for serverless applications. In *17th USENIX Symposium on Networked Systems Design and Implementation (NSDI 20)*, pages 419–434. USENIX Association, 2020.

[2] Devdatta Akhawe and Adrienne Porter Felt. Alice in Warningland: A large-scale field study of browser security warning effectiveness. In *22nd USENIX Security Symposium (USENIX Security 13)*, pages 257–272. USENIX Association, 2013.

[3] Anthropic. Model Context Protocol (MCP): An open protocol for connecting AI applications to external systems. https://modelcontextprotocol.io, 2024.

[4] Sven Apel, Jörg Liebig, Benjamin Brandl, Christian Lengauer, and Christian Kästner. Semistructured merge: Rethinking merge in revision control systems. In *Proceedings of the 19th ACM SIGSOFT Symposium and the 13th European Conference on Foundations of Software Engineering (ESEC/FSE)*, pages 190–200. ACM, 2011.

[5] Manuel Costa, Boris Köpf, Aashish Kolluri, Andrew Paverd, Mark Russinovich, Ahmed Salem, Shruti Tople, Lukas Wutschitz, and Santiago Zanella-Béguelin. Securing AI agents with information-flow control. *arXiv preprint arXiv:2505.23643*, 2025.

[6] Joseph W. Cutler, Craig Disselkoen, Aaron Eline, Shaobo He, Kyle Headley, Michael Hicks, Kesha Hietala, Eleftherios Ioannidis, John Kastner, Anwar Mamat, Darin McAdams, Matt McCutchen, Neha Rungta, Emina Torlak, and Andrew Wells. Cedar: A new language for expressive, fast, safe, and analyzable authorization. *Proceedings of the ACM on Programming Languages*, 8(OOPSLA1):670–697, 2024.

[7] Edoardo Debenedetti, Ilia Shumailov, Tianqi Fan, Jamie Hayes, Nicholas Carlini, Daniel Fabian, Christoph Kern, Chongyang Shi, Andreas Terzis, and Florian Tramèr. Defeating prompt injections by design. *arXiv preprint arXiv:2503.18813*, 2025.

[8] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *Advances in Neural Information Processing Systems (NeurIPS) Datasets and Benchmarks Track*, volume 37, 2024.

[9] Adrienne Porter Felt, Elizabeth Ha, Serge Egelman, Ariel Haney, Erika Chin, and David Wagner. Android permissions: User attention, comprehension, and behavior. In *Proceedings of the Eighth Symposium on Usable Privacy and Security (SOUPS)*, pages 1–14. ACM, 2012.

[10] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *Proceedings of the 16th ACM Workshop on Artificial Intelligence and Security (AISec)*, pages 79–90, 2023.

[11] Sirui Hong, Mingchen Zhuge, Jonathan Chen, Xiawu Zheng, Yuheng Cheng, Jinlin Wang, Ceyao Zhang, Zili Wang, Steven Ka Shing Yau, Zijuan Lin, Liyang Zhou, Chenyu Ran, Lingfeng Xiao, Chenglin Wu, and Jürgen Schmidhuber. MetaGPT: Meta programming for a multi-agent collaborative framework. In *Twelfth International Conference on Learning Representations (ICLR)*, 2024.

[12] Carlos E. Jimenez, John Yang, Alexander Wettig, Shunyu Yao, Kexin Pei, Ofir Press, and Karthik R. Narasimhan. SWE-bench: Can language models resolve real-world GitHub issues? In *Twelfth Inter-*

national Conference on Learning Representations (ICLR), 2024.

[13] Sanjeev Khanna, Keshav Kunal, and Benjamin C. Pierce. A formal investigation of Diff3. In *27th International Conference on Foundations of Software Technology and Theoretical Computer Science (FSTTCS)*, pages 485–496. Springer, 2007.

[14] Taesoo Kim and Nickolai Zeldovich. Practical and effective sandboxing for non-root users. In *2013 USENIX Annual Technical Conference (USENIX ATC 13)*, pages 139–144. USENIX Association, 2013.

[15] Kai Mei, Xi Zhu, Wujiang Xu, Wenyue Hua, Mingyu Jin, Zelong Li, Shuyuan Xu, Ruosong Ye, Yingqiang Ge, and Yongfeng Zhang. AIOS: LLM agent operating system. In *Conference on Language Modeling (COLM)*, 2025. arXiv:2403.16971.

[16] Edmund B. Nightingale, Peter M. Chen, and Jason Flinn. Speculative execution in a distributed file system. In *Proceedings of the ACM SIGOPS 20th Symposium on Operating Systems Principles (SOSP)*, pages 191–205. ACM, 2005.

[17] Donald E. Porter, Owen S. Hofmann, Christopher J. Rossbach, Alexander Benn, and Emmett Witchel. Operating system transactions. In *Proceedings of the ACM SIGOPS 22nd Symposium on Operating Systems Principles (SOSP)*, pages 161–176. ACM, 2009.

[18] Ohad Rodeh, Josef Bacik, and Chris Mason. BTRFS: The Linux b-tree filesystem. *ACM Transactions on Storage (TOS)*, 9(3):9:1–9:32, 2013.

[19] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J. Maddison, and Tatsunori Hashimoto. Identifying the risks of LM agents with an LM-emulated sandbox. In *Twelfth International Conference on Learning Representations (ICLR)*, 2024.

[20] Xingyao Wang, Boxuan Li, Yufan Song, Frank F. Xu, Xiangru Tang, Mingchen Zhuge, Jiayi Pan, Yueqi Song, Bowen Li, Jaskirat Singh, Hoang H. Tran, Fuqiang Li, Ren Ma, Mingzhang Zheng, Bill Qian, Yanjun Shao, Niklas Muennighoff, Yizhe Zhang, Binyuan Hui, Junyang Lin, Robert Brennan, Hao Peng, Heng Ji, and Graham Neubig. OpenHands: An open platform for AI software developers as generalist agents. In *Thirteenth International Conference on Learning Representations (ICLR)*, 2025.

[21] Robert N. M. Watson, Jonathan Anderson, Ben Laurie, and Kris Kennaway. Capsicum: Practical capabilities for UNIX. In *19th USENIX Security Symposium (USENIX Security 10)*, pages 29–46. USENIX Association, 2010.

[22] Charles P. Wright, Jay Dave, Puja Gupta, Harikesavan Krishnan, David P. Quigley, Erez Zadok, and Mohammad Nayyer Zubair. Versatility and Unix semantics in namespace unification. *ACM Transactions on Storage (TOS)*, 2(1):74–105, 2006.

[23] Qingyun Wu, Gagan Bansal, Jieyu Zhang, Yiran Wu, Beibin Li, Erkang Zhu, Li Jiang, Xiaoyun Zhang, Shaokun Zhang, Jiale Liu, Ahmed Hassan Awadallah, Ryen W. White, Doug Burger, and Chi Wang. AutoGen: Enabling next-gen LLM applications via multi-agent conversation. In *First Conference on Language Modeling (COLM)*, 2024.

[24] Yuhao Wu, Franziska Roesner, Tadayoshi Kohno, Ning Zhang, and Umar Iqbal. IsolateGPT: An execution isolation architecture for LLM-based agentic systems. In *Network and Distributed System Security Symposium (NDSS)*, 2025.

[25] John Yang, Carlos E. Jimenez, Alexander Wettig, Kilian Lieret, Shunyu Yao, Karthik Narasimhan, and Ofir Press. SWE-agent: Agent-computer interfaces enable automated software engineering. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 37, 2024.

[26] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking indirect prompt injections in tool-integrated large language model agents. In *Findings of the Association for Computational Linguistics: ACL 2024*, pages 10471–10506. Association for Computational Linguistics, 2024.

A Appendix: Reproducibility and Artifact Guide

The open-source implementation of Aegis OS and the benchmark suite are available at https://github.com/heurion-org/aegis-os. All nine Rust crates (`aos-core`, `aos-policy`, `aos-vfs`, `aos-ipc`, `aos-sandbox`, `aos-egress`, `aos-recorder`, `aos-mcp-gateway`, and `aos-cli`) are self-contained in the workspace. To run all unit tests and reproduce all five empirical experiments (`BENCHMARK_REPORT.md` and `BENCHMARK_REPORT.json`):

```
cargo test --workspace
cargo run --release --bin aegis-os -- bench \
  --report-out BENCHMARK_REPORT.md
```